

Cyber Tabletop Exercise

Ransomware Impact on Retail Payment Operations

Revised facilitator guide

Scenario source: STIX-derived TTX and evaluation feedback provided by the user

Audience: Executive, operational, cyber security, technology, payments, legal/compliance, communications, and business continuity stakeholders

Suggested duration: 90 minutes

Document Control

Field	Details
Exercise title	Ransomware Impact on Retail Payment Operations
Exercise type	Facilitated tabletop exercise (TTX)
Version	Revised version integrating evaluator feedback on technical continuity and ATT&CK lifecycle coverage
Primary environment	Retail payment processing environment supporting ACH, SEPA, domestic transfer, and settlement workflows
Scope of revision	Adds pre-impact indicators, attacker sequence, explicit control bypasses, lifecycle mapping, technical responder prompts, and governance decision points.

Contents

- 1. Exercise Overview
- 2. Objectives
- 3. Scope and Assumptions
- 4. Rules of Engagement
- 5. Scenario Summary
- 6. Participant Roles
- 7. Facilitation Guidance
- 8. Detailed Scenario Timeline and Injects
- 9. Decision Points Summary
- 10. Business and Technical Impacts to Explore
- 11. Success Criteria
- 12. Debrief Questions
- 13. Recommended Improvement Areas
- 14. MITRE ATT&CK Mapping
- 15. Appendix: STIX-to-Scenario Translation
- 16. Optional Visuals for Final PDF Layout
- 17. Facilitator Closing Statement

Revision Focus

This version explicitly incorporates the evaluator feedback by expanding the scenario before ransomware impact, defining the attack path from initial compromise through encryption, explaining how controls were bypassed, and mapping every major attack phase to concrete ATT&CK techniques. Unsupported activity, such as confirmed data exfiltration, is excluded from the core mapping and is treated only as an investigative question if participants raise it.

1. Exercise Overview

Exercise title	Ransomware Impact on Retail Payment Operations
Exercise type	Facilitated tabletop exercise (TTX)
Audience	Executive, operational, cyber security, technology, payments, legal/compliance, communications, and business continuity stakeholders
Suggested duration	90 minutes
Primary environment in scope	Retail payment processing environment supporting ACH, SEPA, domestic transfer, and settlement workflows

Purpose

This tabletop exercise tests the organization's ability to respond to a ransomware incident affecting payment processing systems shortly before settlement deadlines. The scenario stresses operational resilience, executive decision-making, continuity planning, communications, regulatory notification, evidence preservation, identity control, and safe restoration under time pressure.

The revised design also gives technical responders a coherent pre-impact trail to investigate before encryption is confirmed. Participants must reason through how a financially motivated ransomware operator gained access, moved through the environment, bypassed controls, staged the payload, and triggered impact in payment operations.

2. Objectives

By the end of the exercise, participants should be able to:

- Assess, classify, and escalate a disruptive ransomware event affecting critical payment operations.
- Recognize realistic pre-encryption indicators and decide how aggressively to contain before business impact is fully confirmed.
- Coordinate technical containment while preserving evidence and maintaining disciplined incident command.
- Explain the attacker sequence from initial access through ransomware deployment, including entry vector, execution path, propagation method, control bypasses, and conditions enabling impact.
- Decide whether to isolate specific systems, the payment management segment, or the full payment environment.
- Determine when and how to activate payment continuity fallback procedures.
- Prioritize payment flows based on business criticality, settlement obligations, customer impact, liquidity implications, and regulatory expectations.
- Coordinate executive, operational, legal, compliance, communications, risk, and cyber response decisions.
- Evaluate regulator, customer, partner, and internal notification triggers as facts develop.
- Identify safe restoration gates, backup validation requirements, credential reset sequencing, and recovery priorities.
- Map scenario activity to MITRE ATT&CK tactics and techniques and identify defensive control improvements.

3. Scope and Assumptions

In Scope	Payment operations and settlement processing; security operations and incident response; executive crisis management; legal, compliance, and regulatory communications; internal and external stakeholder communications; business continuity and fallback processing; recovery decision-making for affected infrastructure; identity and privileged access controls supporting the payment environment.
Out of Scope	Hands-on technical remediation; detailed malware reverse engineering; procurement or vendor contract negotiation; negotiation with threat actors; technical instructions for deploying malware or exploiting systems.

Assumptions

- The organization has documented incident response, crisis management, payment continuity, backup, and reconnection procedures.
- The payment environment includes production servers, operations shared drives, an administrative jump path, service accounts, backup infrastructure, and interfaces supporting payment submission, reconciliation, and settlement reporting.
- The incident occurs on a normal business day with approximately two hours remaining before end-of-day settlement cut-off when ransomware impact becomes visible.
- Participants should respond using their current roles, responsibilities, authorities, and realistic internal processes.
- A working technical assumption is provided for exercise purposes: the initial compromise began with a targeted phishing email to a payment operations support user, followed by misuse of valid domain credentials and remote administration paths.
- No confirmed data exfiltration is included in the core scenario. Double-extortion risk may be discussed as an investigative hypothesis but should not be treated as established fact unless the facilitator chooses to introduce an optional branch.

- The SOC owns technical detection, containment recommendations, forensic preservation, and threat-hunting execution. The crisis management structure owns enterprise risk decisions, business continuity trade-offs, external communications, and regulatory coordination, with the CISO bridging both forums.

4. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness.
- Real incidents take priority. Participants may step out if required by operational duties.
- Participants should respond as they would in a real event using current processes and authorities.
- There are no perfect answers; the focus is on decision quality, coordination, timing, and identification of gaps.
- Facilitators may provide additional facts if discussion stalls or if participants need technical clarification.
- Reasonable assumptions may be made where playbooks, ownership, or facts are not yet available; assumptions should be documented.
- Do not fight the scenario. The technical facts provided by the facilitator are exercise inputs designed to test decision-making.
- Do not attempt live technical actions during the exercise.

5. Scenario Summary

A financially motivated ransomware operator targets the bank's retail payment processing environment shortly before settlement deadlines. The attacker obtains an initial foothold through a targeted phishing attachment delivered to a payment operations support user. The user opens a malicious file presented as a settlement exception report. The payload establishes outbound command-and-control over ordinary web traffic and downloads a lightweight toolset.

Over the next several hours, the attacker abuses valid domain credentials, discovers payment servers and file shares, and moves through a permitted administrative path into the payment management segment. A legacy payment utility server has incomplete endpoint tamper protection and allows some security service interference. Standing privileges and insufficient restrictions on service account interactive use enable access to systems that support payment batching, reconciliation, and operations shared drives.

Before encryption begins, the SOC receives several pre-impact indicators: unusual PowerShell activity, anomalous service account logons, network service discovery against payment servers, creation of a suspicious scheduled task on an administrative jump server, abnormal SMB access to payment file shares, and attempts to interfere with recovery mechanisms. These signals are ambiguous enough to test whether the organization can act before the business impact is obvious.

The ransomware payload is then staged through the compromised administrative path and executes against payment processing servers and shared operations drives. Payment batches begin failing, visibility into queues degrades, and settlement deadlines are placed at risk. The organization must decide whether to isolate the payment environment, activate fallback procedures, delay lower-priority customer transfers, notify regulators, and sequence recovery without destroying evidence or reintroducing the compromise.

5.1 Technical Attack Sequence

Sequence	Exercise narrative fact	Why it matters
1. Initial foothold	A targeted phishing attachment reaches a payment operations support user. The attachment is themed as a settlement exception report and is opened by the user.	Tests user-reporting, email investigation, endpoint triage, and early incident classification.
2. Execution and beaconing	A script interpreter launches from the malicious file and initiates outbound HTTPS communications to attacker infrastructure.	Tests endpoint detection, proxy/DNS review, egress control, and collection of volatile artifacts.
3. Credential access	The attacker obtains reusable domain credentials and identifies a payment service account with broader access than required.	Tests identity containment, credential reset sequencing, privileged access management, and service-account governance.
4. Discovery	The attacker enumerates domain accounts, payment servers, network services, and shared drives used by payment operations.	Tests threat hunting across authentication, endpoint, network, and file-share telemetry.
5. Lateral movement	The attacker uses valid credentials and permitted remote administration paths to reach a payment administrative jump server and selected payment servers.	Tests segmentation assumptions, remote access controls, and authority for isolation.
6. Persistence and staging	A suspicious scheduled task is created on the payment administrative jump server and ransomware components are staged under a directory that resembles routine maintenance activity.	Tests detection of living-off-the-land behavior and suspicious administrative persistence.
7. Defense evasion and recovery interference	The attacker attempts to reduce visibility and hinder recovery by interfering with endpoint/logging services on a legacy server and attempting to affect local recovery features.	Tests EDR health monitoring, tamper protection, logging resilience, backup isolation, and forensic preservation.
8. Impact	Ransomware encrypts payment processing servers and shared operations drives. Payment batches fail and settlement deadlines are at risk.	Tests crisis governance, business continuity, payment prioritization, notifications, and safe restoration.

5.2 Security Control Bypass Mechanisms

- **Email and content inspection:** the phishing attachment was themed as a legitimate settlement exception report and was not blocked before the user opened it. This tests whether alerts, user reporting, and rapid endpoint isolation compensate when preventive email controls miss a targeted lure.
- **Identity controls:** valid domain credentials and a payment service account with excessive access allow the attacker to blend into normal administrative activity. This tests least privilege, service-account monitoring, privileged access management, and emergency credential revocation.
- **Segmentation and administrative paths:** the attacker does not need to exploit the payment application directly; they traverse a permitted remote administration path into the payment management segment. This tests whether segmentation restricts administrative protocols and whether crisis teams understand blast radius.
- **Endpoint and telemetry controls:** one legacy payment utility server has outdated endpoint policy coverage and incomplete tamper protection. This tests EDR health monitoring, compensating controls, and the ability to detect loss of visibility.
- **Backup and recovery controls:** the attacker attempts to impair local recovery features before encryption. This tests backup immutability, backup access separation, recovery logging, and restoration gates.
- **Clarifying boundary:** the core scenario does not assert confirmed data exfiltration, compromise of the payment application codebase, or a zero-day exploit.

5.3 Pre-Impact Indicators Available to Facilitators

Indicator	Simulated observation	Participant response expected
Endpoint alert	Office-like process launches an unusual script interpreter on a payment operations workstation.	Triage host, preserve evidence, assess user activity, isolate if threshold is met.
Outbound traffic	Proxy/DNS logs show periodic HTTPS connections to a newly observed low-reputation domain.	Review egress logs, block indicators, scope affected hosts, confirm whether C2 is active.
Identity anomaly	Payment service account used interactively outside its normal automation pattern.	Disable or restrict account, identify dependencies, rotate credentials using a planned sequence.
Discovery behavior	Authentication and network logs show enumeration of payment servers, shares, and domain accounts.	Hunt for lateral movement, prioritize critical payment assets, validate segmentation.
Persistence signal	New scheduled task appears on the payment administrative jump server with a misleading maintenance-like name.	Contain jump server, collect task metadata, assess remote execution and privilege level.
Telemetry degradation	One legacy payment utility server stops reporting normal endpoint health telemetry.	Investigate possible defense evasion, use alternate telemetry, avoid assuming absence of evidence.
Recovery interference	Local recovery or backup-related activity is observed before encryption begins.	Protect backups, verify immutability, preserve logs, prevent premature restoration.
Operational symptom	Payment operations notices batch latency and delayed access to shared folders before encryption alerts are confirmed.	Link business symptoms to technical triage and prepare continuity decision options.

6. Participant Roles

Executive / Crisis Management	Executive sponsor / crisis lead; business line leadership for payments; CISO or delegate; COO or delegate; enterprise risk representative.
Operational / Business	Head of payment operations; treasury / liquidity management representative; settlement operations lead; customer service / relationship management representative; business continuity lead.
Technical / Response	SOC lead; incident response lead; infrastructure / platform operations lead; backup and recovery lead; identity and access management lead; network/security architecture representative; payment application owner.
Control Functions	Legal counsel; compliance / regulatory affairs; privacy office; corporate communications / media relations; risk management; audit or assurance observer if appropriate.

Decision Authority Expectations

Decision	Technical owner	Business / governance owner	Required coordination
Isolate user workstation or jump server	SOC / incident response lead	CISO informed; payment operations notified	Confirm operational dependency and evidence preservation.
Disable or rotate payment service accounts	IAM lead / incident response lead	Payment operations owner approves business impact	Sequence to avoid breaking fallback or restoration paths.
Segment or disconnect payment environment	SOC / infrastructure lead recommends and executes	Crisis lead / CISO / payment executive approve risk trade-off	Assess payment deadlines, blast radius, and continuity options.
Activate payment fallback	Payment operations / BCP lead	Crisis lead and business line leadership	Confirm capacity, prioritization, controls, reconciliation, and communications.
Regulatory/customer notification	Legal/compliance/communications	Crisis lead / executive sponsor	Use verified facts from SOC and business impact assessment.
Begin restoration	IR, infrastructure, backup, and application owners	CISO and payment business owner approve restoration gates	Validate eradication, backup integrity, credentials, and monitoring.

7. Facilitation Guidance

Suggested Exercise Flow

Activity	Duration	Purpose
Introduction, objectives, roles, and rules	10 minutes	Set expectations and align participants on exercise scope.
Inject 1: Pre-impact indicators	15 minutes	Test early detection, scoping, containment thresholds, and technical-to-business escalation.
Inject 2: Encryption confirmed and settlement risk	20 minutes	Test immediate containment, payment prioritization, incident command, and continuity decisions.
Inject 3: Containment, fallback, and restoration gates	20 minutes	Test executive decision-making, fallback operations, identity containment, and safe recovery sequencing.
Inject 4: Recovery, notifications, and post-incident management	15 minutes	Test stakeholder communications, regulatory follow-up, lessons learned, and risk reduction.
Final debrief and lessons learned	10 minutes	Capture decisions, gaps, owners, and improvement actions.

What Facilitators Should Watch For

- Whether participants act on pre-impact indicators before encryption is fully confirmed.
- Clarity of authority between SOC technical containment decisions and crisis-cell business decisions.
- Whether participants distinguish containment, eradication, recovery, and restoration validation.
- Evidence preservation considerations before account resets, rebuilding, or restoration.
- Whether identity risk is treated as a central part of the ransomware response.
- Payment prioritization logic, transaction ownership, and documentation of trade-offs.
- Synchronization of technical, executive, legal, regulatory, customer, and media communications.
- Escalation thresholds and timing of regulator notification decisions.
- Whether participants challenge assumptions about fallback capacity, manual controls, and reconciliation.
- Whether ATT&CK mapping is used to identify control gaps rather than as a checklist exercise.

Facilitator note: The scenario should not become a technical forensics drill. Use technical details to drive decisions: isolate now or monitor, disable account now or sequence, activate fallback now or wait, restore from backup or rebuild, notify now or gather more facts.

8. Detailed Scenario Timeline and Injects

Inject 1: Pre-Impact Indicators and Attack Path Scoping

Simulated time: T-6 hours before end-of-day settlement

Inject

The SOC identifies a cluster of suspicious events involving a payment operations workstation, a payment service account, and the payment administrative jump server. Payment operations also reports unusual latency in payment batch validation and intermittent access delays to shared folders. Ransomware has not yet been confirmed, but the event pattern suggests a possible active intrusion in or near the payment environment.

Technical Evidence Available if Requested

- Endpoint alert: unusual script interpreter launched from a settlement-themed document on PAYOPS-WS14.
- Identity alert: service account svc_pay_batch used interactively from a non-standard host.
- Network alert: payment servers scanned from the administrative jump server.
- Persistence indicator: newly created scheduled task on JUMP-PAY-01 with a maintenance-like name.
- Telemetry gap: PAY-UTIL-02 endpoint agent health check missing for 25 minutes.

What Participants Know

- A payment operations user opened a settlement-themed attachment earlier in the day.
- Endpoint telemetry shows unusual script execution from the user's workstation.
- A payment service account has been used interactively, which is inconsistent with its normal automation pattern.
- Authentication and network telemetry show enumeration of payment servers and operations file shares.
- A suspicious scheduled task has appeared on the payment administrative jump server.
- One legacy payment utility server has stopped reporting normal endpoint health telemetry.
- Operations has not yet missed settlement deadlines, but batch latency is increasing.

Discussion Questions

- What is the initial incident classification and who owns the decision to escalate?
- What additional facts are required within the next 15 minutes to determine whether this is an active ransomware precursor?
- Should the payment operations workstation, service account, or administrative jump server be isolated immediately?
- Who has authority to disable or rotate the payment service account, and what operational dependencies must be checked first?
- What evidence must be preserved before containment actions change the environment?
- Should payment operations prepare fallback procedures at this stage even though encryption is not yet confirmed?
- What should be communicated to executives, payment operations, legal/compliance, and business continuity at this stage?

Expected Actions

- Establish incident command and open a technical-to-business escalation path.
- Preserve endpoint, identity, network, proxy/DNS, and file-share telemetry.
- Contain the initial workstation and suspicious jump-server activity if thresholds are met.
- Suspend or constrain the service account after identifying critical dependencies.
- Block known indicators and begin threat hunting across payment-adjacent systems.
- Prepare a rapid business impact assessment focused on settlement timing and fallback capacity.
- Document assumptions, decisions, evidence sources, and decision owners.

Facilitator Notes

Strong responses should not wait for encryption before acting. Look for a balanced approach: contain the most suspicious assets, avoid uncontrolled disruption to payment operations, preserve evidence, and prepare the crisis management structure for a potential business-impacting event.

Inject 2: Operational Disruption and Confirmed Encryption Alerts

Simulated time: T-2 hours before end-of-day settlement

Inject

Payment operations reports failed payment batches and a growing processing backlog. The SOC confirms ransomware activity on payment processing servers and associated operations file shares. The suspected path is now clearer: the attacker used valid credentials and the payment administrative jump server to stage and execute the ransomware payload across systems reachable through remote administration channels.

Technical Evidence Available if Requested

- Ransomware observed on PAY-BATCH-02, PAY-RECON-01, and payment operations shared drives.
- SMB/admin-share activity from JUMP-PAY-01 to payment servers shortly before encryption.
- Service stop events occurred before encryption on affected servers.
- Attempted local recovery interference observed on at least one payment server.
- No evidence yet that payment messages were altered; availability is the primary known impact.

What Participants Know

- Payment batches are failing in the retail payment processing environment.
- Shared operations drives used by payment teams are becoming inaccessible.
- Ransomware activity has been confirmed on payment processing servers.
- Some application and database services were stopped shortly before encryption began.
- End-of-day settlement is two hours away.
- Customer transfers, domestic payments, and selected priority flows may be impacted.
- No confirmed external data exfiltration has been identified at this stage.

Discussion Questions

- Who is accountable for directing the immediate technical response and who is accountable for business continuity decisions?
- Which systems, user groups, service accounts, and interfaces must be isolated immediately?
- Should the organization isolate the full payment environment or only affected segments?
- What are the most critical payment services and flows to preserve or recover first?
- What criteria determine whether fallback procedures should be activated now versus later?
- What facts must be known before executives decide on payment delays or suspension?
- What are the regulatory, customer, and counterparty notification considerations at this stage?

Expected Actions

- Confirm blast radius and affected dependencies across servers, file shares, credentials, backups, and interfaces.
- Contain affected servers and restrict lateral movement opportunities from the administrative path.
- Disable, reset, or constrain compromised credentials using a sequenced plan.
- Preserve logs, volatile artifacts, ransomware notes, and forensic images where feasible.
- Activate crisis management and maintain a single decision log.
- Prepare payment continuity and prioritization options for executive decision.
- Issue internal communications to impacted operations teams with clear do/do-not guidance.

Facilitator Notes

This phase should expose whether participants can connect technical propagation to business impact. Strong answers should separate immediate containment from restoration and should avoid restoring systems before identity compromise and persistence have been addressed.

Inject 3: Executive Decision Point, Fallback Processing, and Restoration Gates

Simulated time: T-90 minutes before settlement cut-off through several hours later

Inject

Executives must decide whether to isolate the entire payment environment, activate manual or alternate payment processing, delay customer transfers, and notify regulators before settlement cut-off. Containment reduces further spread, but encryption has rendered multiple payment servers and shared operational resources unavailable. The incident response team advises that restoration should not begin until evidence is preserved, compromised credentials are addressed, and recovery sequencing is approved.

What Participants Know

- The ransomware is active in the payment zone, but immediate spread appears limited after containment.
- Full isolation would likely reduce further damage but may halt additional payment processing.
- Partial operations may still be possible through documented fallback procedures.

- Priority payments may be processed with reduced capacity if specific dependencies remain available.
- Customer and counterparty impact will become visible soon.
- Backup integrity is not yet fully validated.
- The suspicious scheduled task and service account misuse must be remediated before restoration.

Discussion Questions

- Who has authority to order full isolation of the payment environment?
- What threshold triggers continuity mode and who approves it?
- Which payment types should be prioritized and why?
- Should lower-priority customer transfers be delayed to preserve capacity for critical obligations?
- What conditions must be met before restoration begins?
- How should recovery be sequenced across credentials, servers, shared drives, interfaces, and payment visibility tools?
- How does the team validate backups and prevent reinfection?
- What preliminary notifications should be prepared before settlement cut-off?

Expected Actions

- Make a time-bound executive decision on containment versus continuity.
- Activate manual or alternate payment processing for priority transactions if authorized.
- Implement payment triage based on contractual obligations, settlement deadlines, customer harm, liquidity, and regulatory expectations.
- Approve restoration gates requiring evidence preservation, eradication confidence, credential reset, backup validation, and monitoring readiness.
- Prioritize recovery of systems enabling settlement, reconciliation, payment queue visibility, and operational control.
- Continue fallback processing and reconcile manual actions with system-of-record requirements.
- Prepare regulator notification decisioning and draft stakeholder messages.

Facilitator Notes

Good responses should include restoration gates, identity cleanup, backup validation, and a clearly sequenced service recovery plan rather than a simple “restore everything” approach. This inject should also reveal whether fallback procedures are operationally realistic under time pressure.

Inject 4: Recovery, Notification, and Post-Incident Management

Simulated time: Next business period

Inject

The payment environment is being restored in a controlled sequence. Critical systems are returning, but some transfers were delayed and selected customers experienced disruption. Executives must determine the scope of regulatory follow-up, customer messaging, internal reporting, lessons learned, and immediate risk reduction before full normalization.

What Participants Know

- Core payment capabilities are returning after controlled restoration.
- The backlog is being worked through in priority order.
- Settlement disruption was at least partially realized.
- No confirmed data exfiltration has been found, but monitoring continues.
- The incident may trigger internal reporting, external notifications, and formal lessons-learned activities.
- Several control gaps are suspected: excessive service account permissions, administrative path exposure, incomplete endpoint coverage on a legacy server, and insufficient pre-impact escalation triggers.

Discussion Questions

- What should be included in regulator notifications or follow-up reporting?
- How should the bank communicate with affected customers and counterparties?
- What internal decision records, technical evidence, and business impact metrics must be retained?
- What controls or process gaps most contributed to the incident impact?
- What immediate risk reduction actions are required before normal operations fully resume?
- How should the organization monitor for reinfection, delayed impact, or attempted extortion claims?
- What should be measured during the post-incident review?

Expected Actions

- Complete stakeholder communications and regulatory reporting as required.
- Finalize business and technical recovery validation.
- Document decision timelines, containment steps, system impacts, customer impacts, and escalation effectiveness.
- Launch after-action review and remediation planning.
- Track corrective actions relating to segmentation, identity, service-account governance, endpoint coverage, backup readiness, continuity procedures, detection engineering, and authority clarity.
- Confirm heightened monitoring, credential hygiene, and payment reconciliation before declaring final closure.

Facilitator Notes

This final phase should draw out lessons learned, not just closure. Participants should identify concrete improvements in resilience, governance, communications, detection, identity control, and restoration readiness.

9. Decision Points Summary

Key decisions expected during the exercise include:

- Whether pre-impact indicators justify isolating the payment operations workstation, administrative jump server, or service account before encryption is confirmed.
- Whether to disable, rotate, or constrain payment-related service accounts immediately, and how to manage dependencies.
- Whether to isolate the full payment environment or only affected segments.
- Whether to activate payment continuity fallback procedures.
- Which payment flows to prioritize under degraded conditions.
- Whether to delay or suspend selected customer transfers.
- When to notify regulators and what preliminary facts to disclose.
- When to begin restoration and under what technical and business gates.
- How to communicate with customers, counterparties, partners, internal executives, and the media.
- When the incident can move from crisis response to recovery governance and post-incident remediation.

Decision Log Template for Facilitators

Time	Decision required	Options considered	Decision owner	Decision made	Evidence / assumptions	Follow-up owner
T-6h	Pre-impact containment	Monitor / isolate workstation / isolate jump server / disable account	SOC lead + CISO			
T-2h	Payment-zone isolation	Targeted isolation / full isolation / maintain partial operations	Crisis lead + CISO			
T-90m	Fallback activation	No fallback / partial fallback / full continuity mode	Payment executive + BCP lead			
T-90m	Payment prioritization	Critical only / priority customer set / chronological processing	Payment operations lead			
Recovery	Restoration authorization	Restore from backup / rebuild / keep isolated	CISO + payment owner			
Recovery	Notifications	Internal only / regulator / customers / counterparties / media holding statement	Legal/compliance + crisis lead			

10. Business and Technical Impacts to Explore

Business impacts	Missed or delayed settlement deadlines; delayed customer transfers and complaints; liquidity management pressure; increased operational workload due to manual processing; counterparty confidence concerns; reputational damage and scrutiny from partners and regulators; risk of reconciliation errors during fallback processing.
Operational impacts	Reduced capacity for payment validation; degraded visibility into payment queues; manual prioritization and exception handling; increased reliance on relationship managers and customer support; pressure to process critical transactions before technical safety is fully confirmed.
Technical impacts	Encryption of payment servers and shared drives; compromise of payment-adjacent workstation and administrative jump path; misuse of service accounts; potential loss of endpoint telemetry on a legacy server; possible interference with local recovery mechanisms; need for containment, forensics, credential reset, backup validation, and safe restoration.
Control impacts	Failure or bypass of email prevention, endpoint monitoring, privileged access governance, segmentation, logging coverage, and pre-impact escalation thresholds; need to validate backup immutability and recovery rehearsals.

11. Success Criteria

- Clearly identify incident leadership, decision authority, and handoffs between SOC, CISO, crisis management, business operations, legal/compliance, and communications.
- Act on pre-impact indicators using defined thresholds and preserve evidence while containing risk.
- Explain a coherent attack path from phishing through execution, credential abuse, discovery, lateral movement, persistence, control bypass, and ransomware impact.
- Make timely containment and continuity decisions under settlement pressure.
- Prioritize critical payment flows using documented criteria.
- Align technical, operational, legal, regulatory, and executive actions.
- Demonstrate a credible approach to regulator, customer, counterparty, and internal communications.
- Define safe restoration criteria, including backup validation, identity cleanup, persistence removal, and monitoring.
- Identify concrete improvements after the exercise and assign owners.

12. Debrief Questions

- What decisions were made well, and why?
- Where were authorities, escalation paths, or accountabilities unclear?
- Did the organization act early enough on pre-impact indicators?
- Was the technical attack sequence understood well enough to guide containment and restoration?

- Were control bypass mechanisms identified and translated into remediation actions?
- Was the threshold for activating continuity procedures well understood?
- Did participants have enough information to prioritize payments effectively?
- Were communications timely, accurate, and appropriately coordinated?
- Did the organization demonstrate a safe and realistic restoration approach?
- Were identity, service accounts, and administrative access paths handled as part of recovery?
- What capabilities, playbooks, or dependencies need improvement?

Observer Confidence Ratings

Capability	1 Not confident	2 Slightly	3 Somewhat	4 Fairly	5 Completely	Evidence / comments
Pre-impact detection and escalation						
Technical containment and evidence preservation						
Identity and privileged access response						
Payment continuity and prioritization						
Executive decision-making under settlement pressure						
Regulatory/customer communications						
Safe restoration and backup validation						
ATT&CK-informed lessons learned						

13. Recommended Improvement Areas

Potential improvement themes include:

- Payment environment segmentation and administrative-path restriction.
- Privileged access management, service-account governance, interactive logon restrictions, and emergency credential rotation runbooks.
- Endpoint detection coverage, tamper protection, and health monitoring for legacy payment utility servers.
- Detection engineering for pre-ransomware behaviors: unusual script execution, suspicious scheduled tasks, anomalous service account activity, lateral movement, service stops, recovery interference, and telemetry gaps.
- Backup integrity validation, immutability, restoration rehearsal, and recovery gate checklists.
- Payment continuity playbooks, transaction prioritization criteria, capacity assumptions, reconciliation controls, and manual-processing evidence.
- Executive decision frameworks for cyber-disruptive events affecting critical business services.
- Regulator notification thresholds, templates, and decision records.
- Internal communications and stakeholder coordination across SOC, crisis management, payments, legal, compliance, and relationship management.
- Forensic preservation procedures before rebuilding, restoring, or rotating credentials.
- Metrics for time to classify, time to escalate, time to isolate, time to activate fallback, time to notify, and time to restore critical payment capability.

14. MITRE ATT&CK Mapping

The following ATT&CK tactics and techniques are explicitly reflected in the revised exercise narrative. Techniques are included only where the scenario now provides a concrete simulated fact or a defined facilitator evidence item. Confirmed data exfiltration is not included in the core mapping.

14.1 Lifecycle Mapping

Lifecycle tactic	Technique	How it appears in the scenario	Inject(s)	Defensive focus
Initial Access	T1566.001 – Phishing: Spearphishing Attachment	Settlement-themed attachment delivered to a payment operations support user.	1	Email investigation, user reporting, endpoint isolation, phishing response.
Execution	T1204.002 – User Execution: Malicious File; T1059.001 – Command and Scripting Interpreter: PowerShell	User opens malicious file; script execution launches from the workstation.	1	Endpoint telemetry, process chain review, host containment.
Persistence	T1053.005 – Scheduled Task/Job: Scheduled Task	Suspicious scheduled task created on payment administrative jump server.	1, 2	Task inventory, persistence removal, jump-server containment.
Privilege Escalation	T1078.002 – Valid Accounts: Domain Accounts	Misused domain/service account has broader access than required and is used beyond normal pattern.	1, 3	Least privilege, service-account controls, privileged access reviews.
Defense Evasion / Stealth	T1685 – Disable or Modify Tools; T1070 – Indicator Removal	Attacker attempts to interfere with endpoint/logging visibility on a legacy payment utility server.	1, 2	EDR health monitoring, tamper protection, alternate telemetry, log retention.
Credential Access	T1003 – OS Credential Dumping	Reusable domain credentials are obtained after the initial foothold; exact tool details are not exercised.	1	Credential reset sequencing, memory/endpoint forensics, identity detection.
Discovery	T1087 – Account Discovery; T1018 – Remote System Discovery; T1046 – Network Service Discovery	Adversary enumerates domain accounts, payment servers, services, and file shares.	1	Hunt queries, network telemetry, account enumeration alerting.
Lateral Movement	T1021.002 – Remote Services: SMB/Windows Admin Shares	Valid credentials and remote administration paths are used to reach payment servers.	1, 2	Segmentation, admin protocol restriction, jump-server governance.
Command and Control	T1071.001 – Application Layer Protocol: Web Protocols; T1105 – Ingress Tool Transfer	Outbound HTTPS beaconing is observed and tools/payloads are staged into the environment.	1, 2	Egress filtering, DNS/proxy review, C2 blocking, tool staging detection.
Impact	T1486 – Data Encrypted for Impact; T1490 – Inhibit System Recovery; T1489 – Service Stop	Ransomware encrypts payment servers and shared drives; recovery interference and service stop activity precede impact.	2, 3	Backup immutability, service monitoring, restoration gates, business continuity.

14.2 Mapping Notes

- T1486 is the strongest direct mapping because the central incident is ransomware encryption affecting payment processing systems and shared operations drives.
- T1490 and T1489 are included because the scenario explicitly introduces pre-impact recovery interference and service stop behavior before encryption.
- T1566.001, T1204.002, T1059.001, T1071.001, T1105, T1053.005, T1078.002, T1003, T1087, T1018, T1046, and T1021.002 are included as explicit facilitator-provided simulated facts added to complete the technical lifecycle.
- T1041 – Exfiltration Over C2 Channel is intentionally not included in the core mapping because no data exfiltration is confirmed in the scenario. It may be raised as an investigative consideration only.
- The mapping is intended to support discussion of controls, visibility, and decision-making. It should not be treated as proof of a specific real-world threat actor or malware family.

14.3 ATT&CK-to-Control Discussion Prompts

ATT&CK phase	Control questions for participants
Initial Access / Execution	How quickly can we connect a user-reported suspicious email to endpoint process telemetry and business service risk?
Credential Access / Privilege Escalation	Which service accounts can access payment systems, who owns them, and how quickly can they be disabled or rotated safely?
Discovery / Lateral Movement	Can we distinguish normal payment administration from suspicious enumeration and remote administrative access?
Defense Evasion / Stealth	How do we detect endpoint or logging health degradation, especially on legacy systems?
Command and Control	Do proxy, DNS, and endpoint tools allow rapid scoping of outbound suspicious traffic?
Impact	Are backups immutable, tested, and recoverable without reintroducing compromised credentials or persistence?

15. Appendix: STIX-to-Scenario Translation

Key STIX Elements Used

STIX-style element	Scenario translation
Target organization	Banking organization in financial services.
Threat actor	Financially motivated ransomware operator.
Infrastructure targeted	Retail payment processing environment, payment servers, operations shared drives, administrative jump path, and supporting identity dependencies.
Malware	Enterprise ransomware payload affecting availability of payment systems.
Attack pattern	Phishing-enabled foothold; credential misuse; discovery; lateral movement through remote administration; persistence; defense evasion; recovery interference; encryption for impact.
Incident	Ransomware affecting retail payment operations shortly before settlement cut-off.
Courses of action	Contain and preserve evidence in the payment zone; restrict credentials and lateral movement; activate payment continuity fallback; validate backups; restore in a controlled sequence; communicate with regulators and affected stakeholders.

Design Logic

- Translated the original ransomware incident into a timed facilitated exercise.
- Moved the first inject earlier in the kill chain so participants can act on pre-encryption indicators.
- Expanded decision pressure around settlement deadlines and payment prioritization.
- Converted technical activity into business-relevant decisions without turning the exercise into hands-on remediation.
- Converted courses of action into expected participant responses.
- Clarified that SOC leads technical containment while crisis management leads business continuity, external communications, and enterprise risk decisions.
- Added executive, operational, technical, legal, regulatory, risk, and communications perspectives.
- Mapped the lifecycle to MITRE ATT&CK for analytical closure and lessons learned.

Glossary

Acronym / term	Meaning in this exercise
ACH	Automated Clearing House payment processing.
BCP	Business Continuity Plan / business continuity procedures.
C2	Command-and-control communications between compromised systems and attacker infrastructure.
CISO	Chief Information Security Officer or delegate.
EDR	Endpoint Detection and Response tooling.
IAM	Identity and Access Management.
IOC	Indicator of Compromise.
IR	Incident Response.
PAM	Privileged Access Management.
RTO / RPO	Recovery Time Objective / Recovery Point Objective.
SEPA	Single Euro Payments Area payment workflow.
SIEM	Security Information and Event Management.
SOC	Security Operations Center.
TTX	Tabletop Exercise.

16. Optional Visuals for Final PDF Layout

- One-page scenario timeline graphic showing pre-impact activity, encryption impact, executive decision point, fallback processing, and recovery.
- Payment operations dependency map showing payment applications, shared drives, service accounts, administrative jump path, backups, interfaces, and settlement dependencies.
- Decision log table for facilitators.
- RACI-style responsibility matrix for isolation, service-account action, fallback activation, regulator notification, and restoration.
- MITRE ATT&CK lifecycle summary table.
- Heat map of control gaps: email, endpoint, identity, segmentation, backup, detection, continuity, communications.

17. Facilitator Closing Statement

This exercise is intended to help the organization evaluate whether its cyber incident response, payment continuity, crisis governance, regulatory communication, identity control, and recovery processes are sufficient to manage a ransomware event affecting time-sensitive retail payment operations. The emphasis is on practical coordination, early action on pre-impact indicators, timely executive decisions, disciplined evidence preservation, and safe recovery under pressure.

The exercise should close with a decision log review, a list of confirmed gaps, accountable owners, target remediation dates, and a plan to retest improved capabilities through a focused follow-up exercise.